

Trame de rapport d'audit — Infrastructure & Sécurité d'eRezo

Modèle à remplir par votre société de conseil. Remplacez chaque bloc en italique par votre analyse. Le rapport final est rendu en PDF le **vendredi 17 juillet 2026**, à partir du travail réalisé **en séance**. Soyez concis et factuel : un bon rapport tient en 5 à 8 pages.

Page de garde

- **Rapport d'audit** : Infrastructure & Sécurité — eRezo
- **Réalisé par (votre société de conseil)** : *nom de votre société*
- **Consultant(s)** : *vous, seul ou avec votre associé*
- **Client** : KodeSaaS — Maxime Nicole (propriétaire d'eRezo)
- **Date de l'audit** : *date*
- **Périmètre** : production <https://erezo.fr> (lecture seule) — infrastructure & sécurité, hors code source
- **Autorisation de test signée** : *oui / n° annexe*

1. Résumé exécutif

En 5-8 lignes, pour votre client :

- *État général côté infrastructure et sécurité (sain / à surveiller / à risque)*
- *Les 2-3 points les plus importants*
- *Votre recommandation principale pour la V2*

Score de risque global (sécurité) : *X* / 10

Sévérité	Nombre de failles
Critique (P0)	<i>n</i>
Haute (P1)	<i>n</i>
Moyenne / Basse (P2)	<i>n</i>

2. Audit de l'infrastructure

Tout ce que vous avez pu observer de l'extérieur. Pour chaque point : ce que vous constatez, et pourquoi c'est un problème (ou pas).

Hébergement : Où et comment l'application semble hébergée (serveur, hébergeur, CDN...), et comment vous l'avez identifié (DNS, en-têtes...). Écrivez « non confirmé » si vous n'êtes pas sûr.

HTTPS / certificat : Le site est-il en HTTPS ? Le certificat est-il valide et correctement configuré ?

En-têtes HTTP & configuration : En-têtes de sécurité présents ou absents, messages d'erreur trop bavards, pages ou fichiers exposés qui ne devraient pas l'être, robots.txt, etc.

Traces de « fait vite » : Environnement de dev visible en prod, informations techniques qui fuient, incohérences...

Verdict infrastructure : points forts / points faibles / recommandations.

3. Audit de sécurité (pentest — OWASP)

Rappel : **lecture seule, non destructif**. Aucune donnée personnelle réelle ne doit apparaître dans ce rapport (anonymisez).

Méthodologie : outils / agents IA utilisés, phases (reconnaissance → tests → vérification).

Findings

Pour **chaque faille** trouvée, remplissez :

[FIND-00X] Titre

- **Sévérité** : Critique / Haute / Moyenne / Basse · **Priorité** : P0 / P1 / P2
- **Zone concernée** : page, endpoint, fonctionnalité...
- **Description** : en quoi consiste la faille.
- **Preuve** : comportement observé, capture anonymisée.
- **Impact** : ce que ça permet à un attaquant.
- **Correction recommandée** : ...

(Dupliquez ce bloc pour chaque finding.)

Points positifs (ce qui est bien sécurisé)

Listez ce qui résiste. Un bon auditeur note aussi ce qui va bien.

Plan de remédiation priorisé

Priorité	Faille	Effort estimé	Impact
P0	...	faible/moyen/élevé	...
P1	...	...	...
P2	...	...	...

4. Recommandations pour la V2

Comment reconstruire eRezo, bien hébergé et sécurisé. Pour chaque thème : la bonne pratique et ce que vous recommandez concrètement au client. Vous n'êtes pas obligés d'employer le vocabulaire technique exact.

Une infrastructure propre et fiable : Hébergement, HTTPS partout, séparation dev / production, sauvegardes.

Une application sécurisée : Les règles pour éviter précisément les failles trouvées (contrôle des accès, en-têtes de sécurité, configuration, données exposées).

Une mise en ligne maîtrisée : Un déploiement propre, ce qui se passe entre « ça marche sur mon poste » et « c'est en production ».

Le respect des données des utilisateurs : Les règles de base sur les données personnelles.

Un socle fait pour durer (pour aller plus loin) : Ce qui rend le projet solide et reprenable (organisation, tests, documentation).

5. Synthèse des recommandations

Top 5 des actions à conseiller au client, dans l'ordre où vous lui conseillez de les traiter.

1. ...
2. ...
3. ...
4. ...
5. ...

Annexe — Audit croisé

Commentaires reçus d'une autre société (autre groupe) sur votre rapport (séance 5) et comment vous les intégrez.